Leonard Sambu

Security Researcher | Smart Contract Auditor | AI Agent Engineer | Fullstack Developer

+254 739 720 531 cheruiyootsambu@gmail.com /in/cheruiyoot-sambu
github.com/llakterian llakterian.github.io @llakterian

Professional Summary

Most of my work is finding arithmetic bugs in code that holds other people's money, then writing the proof that stops anyone from waving them away.

Across 60+ bug bounty programs on HackenProof, Cantina, Bugcrowd, Intigriti and Immunefi — 20+ of them smart contract audits — the findings I am proudest of are arithmetic. An underflow in Frax's `sfrxETH` withdrawal path, where a cached `totalAssets` drifts against the live figure and strands LP redemptions. A payout path in `tokenize.it` where a caller-supplied base price lets a co-investor walk off with an entire exit. Both ship as runnable Foundry proofs-of-concept, the `sfrxETH` one verified against a live mainnet fork. I run audits with AI agents in parallel lanes across governance, ledger and write-path surfaces, then verify every claim by hand.

A large share of that work ends with me not filing. Three of my own reports were closed by triagers, two as intended behaviour, so I work to a written gate that stops me filing anything a privileged role could reach — and I built the tooling around it: `c0bw3b`, a 13,000-line Python pipeline with 31 decorator-registered modules and 107 passing tests, MIT licensed and installed as a CLI.

I build as much as I break. **C. Sambu Farm Manager** replaced the physical payroll workbook of a tea estate running 20–30 pluckers and 12–39 tonnes of green leaf a month, pricing piece-rate, day-rate and prorated pay in one engine. **Maziwa Coop** sends dairy farmers their delivery confirmation by SMS and generates the month-end statements they used to write by hand. The CRUD was never the hard part — the domain was: a feed-ration solver built on KALRO nutrient tables, tea factory rates that change by effective date, and dates that stay correct in EAT.

I also take paid incident response and forensics on WordPress estates, and build lead pipelines on Cloudflare. I run teams across media, education and tech, so I can sit with a farmer over their deduction statement and with an auditor who thinks their finding will not pay.

Technical Skills

Security & Auditing	Smart contract auditing, vulnerability research, penetration testing, threat modeling, code review, responsible disclosure, OWASP Top 10, digital forensics, IDOR/BOLA, XSS (stored/blind), SQLi, SSRF, CORS/CSRF
Blockchain	Solidity, Foundry, Hardhat, Slither, Mythril, Echidna, EVM internals, proxy patterns (UUPS/Transparent), ERC-4626, cross-chain bridge security, ERC-8004, ERC-4337
Languages	TypeScript, JavaScript, Solidity, Python, Bash, Dart
Fullstack	React 18/19, Next.js, Node.js, Hono.js, Express.js, RESTful APIs, Web3.js, Ethers.js, Viem, Zustand, Recharts, Tailwind CSS, Flutter
AI & LLMs	Claude API (Sonnet 3.5/4), Groq API, Gemini, MCP (Model Context Protocol), Agentic AI Orchestration, Prompt Engineering, Deepseek, NVIDIA NIM, Llama 3.3 70B
DevOps & Infra	Git, Docker, Foundry, JIRA, Trello, CI/CD, Cloudflare Workers, Cloudflare Pages, Cloudflare D1/KV/R2, Wrangler CLI, Netlify, Supabase, Vercel, Postman/Newman
Other	Linux, macOS, Windows, DaVinci Resolve, OBS Studio, Google Workspace, Microsoft Office, Notion, Linear
Media & Video	DaVinci Resolve, OBS Studio, live broadcast direction, multi-camera switching, sound design, post-production editing, scriptwriting, AI video generation, motion graphics

Independent Security Research

Security Researcher & Bug Bounty Hunter

Independent

2024 – Present

- Audited 20+ smart contract codebases (Frax, Paxos, USDai, Cetus, Revert, Alberich, Zendex, DreamX) and worked 40+ Web2 programs on HackenProof, Cantina, Bugcrowd, Intigriti and Immunefi.
- Reported an arithmetic underflow in Frax's `sfrxETH` withdrawal path (cached `totalAssets` drift stranding LP redemptions) and a caller-supplied base price in `tokenize.it`'s exit payout draining 100% of proceeds; both shipped as runnable Foundry PoCs, the first verified against a live mainnet fork.
- Found a critical blind stored XSS executing inside an internal backoffice exposing national IDs and phone numbers, and an IDOR in a B2B platform that was triaged and rewarded.
- Built the verification stack: Foundry, Hardhat and Sui test suites, mainnet forks, gas measurement, on-chain state reads, plus a standing filing

gate that keeps privileged-role findings out of the queue before review.
- Ran audits with AI agents in parallel lanes across governance, ledger and write-path surfaces; confirmed every claim by hand; wrote triage-ready reports with severity classification, root cause analysis, remediation steps, and dismissal vectors already considered.

Key Projects

Full portfolio with live links: llakterian.github.io

Maziwa Coop — Milk Cooperative Management System

maziwa-coop.pages.dev

Production platform for Kenyan dairy cooperatives replacing paper delivery records with daily milk logging, auto-generated ticket numbering, Africa's Talking SMS confirmations to farmers, milking-can credit tracking, and CSV reporting. SMS provider abstracted for zero-core-change swaps. Stack: React 19, Hono.js on Cloudflare Workers, D1, Zustand, Recharts.

C. Sambu Farm Manager — Full-Stack Farm Management PWA

Live API

PWA for a multi-sector Kenyan agribusiness (tea, dairy, avocado, poultry) replacing a physical payroll workbook (20–30 pluckers, 12–39t green leaf/month). Single payroll engine prices piece-rate (KES 9/kg), day-rate and prorated salary. Feed-ration solver on KALRO nutrient tables, effective-dated tea factory rates, Open-Meteo weather across 14 Kenyan regions, Workbox offline caching. Migrated IndexedDB/FastAPI/Docker to Cloudflare Workers + D1.

Shambani — AI Agronomy & Weather Advisory

shambani-app.pages.dev

Weather intelligence for all 47 Kenyan counties: current conditions, 7-day forecast, AI agronomic advice grounded in KALRO, Tea Research Foundation of Kenya, and Ministry of Agriculture extension guidelines, plus livestock feed profiling. API keys server-side behind single proxy chokepoint, 5-min cache with stale-on-error fallback. Stack: FastAPI + Cloudflare Pages Functions, Groq (gpt-oss-20b), Open-Meteo, vanilla-JS PWA.

QuitVaping — AI Cessation Platform

quitvaping.netlify.app

Production Flutter web PWA for nicotine cessation: abstinence tracking, health-recovery timeline, savings calculator, AI coach, craving-pattern analysis, guided panic-mode breathing, NRT tracking, community support, monetised via RevenueCat. Full MCP client stack, Supabase backend with edge functions and web push. 36k lines Dart across 117 files, Postman/Newman API test suite.

c0bw3b Toolkit — Automated Reconnaissance & Vulnerability Scanner

Custom automated scanning pipeline for Web2 bug bounty. 13,000 lines Python across 31 decorator-registered modules: passive/active recon, JavaScript secret extraction, port scanning, historical URL collection (Wayback, CommonCrawl), CORS/IDOR/SQLi/SSRF detection, false-positive verification, attack-chain correlation. 107 passing tests. MIT licensed, installs as `c0bw3b` CLI.

FinPro — Decentralized Project & Finance Platform

Client delivery: escrow-based payments, ERC-20 token, swap module, multisig treasury, EIP-4337 gasless accounts with token paymaster, Telegram Mini App. 7 audited Solidity contracts, 33 passing Hardhat tests, Playwright E2E coverage; Supabase with RLS, Stripe checkout, TON sidechain data registry.

BotIn — Decentralized AI Agent Network

Decentralized AI agent professional network utilizing ERC-8004 for agentic identities, on-chain reputation, and XMTP messaging.

NimbusTrade — Web3 Arbitrage Dashboard

Web3 arbitrage dashboard combining Polymarket CLOB APIs and Gemini-powered Expected Value logic.

PicKut AI — AI Image Editing Suite

Professional image editing suite powered by Gemini 2.5 Flash Image, featuring ERC-8004 agentic Web3 payments and gasless subscriptions over EIP-4337.

Uplift News — Multi-Language News Platform

Multi-language platform with React, Cloudflare Workers, D1, and Groq AI for bilingual English/Swahili content curation. Installable PWA with push notifications.

SafeShamba — Secure Land Purchase with Multisig Custody

safeshamba.us.ci

Notary-mediated escrow platform for land acquisition with multisig custody and state-gated fund releases. Four-phase workflow: intake and discovery, safety gate with due diligence, execution and fiat bridge, transfer registry. Solidity 0.8.19 contracts (EscrowFactory, NotaryMediatedEscrow, MultiSigWallet) audited and tested with Foundry (21 passing tests) and Slither. React 18 frontend with Vite, ethers.js, and motion-based folder UI. Deployed on Sepolia testnet and Cloudflare Workers. MIT license with commercial agreement.

Professional Experience

Technology Consultant & Developer

Self-Employed

Sep 2023 – Present

- Built and deployed production full-stack applications (Maziwa Coop, Sambu Farm Manager) on Cloudflare's serverless edge with JWT auth, RBAC, and live D1 schema migrations.
- Paid incident response and forensics on WordPress estates: recovered client across four outages, removed PHP webshell and eight hidden admin accounts, rotated salts, cut TTFB from 30s+ to 1.1s.
- Architected lead pipeline connecting Meta Lead Ads to CRM via Cloudflare Workers + KV, with Zapier bridge around Meta's App Review restriction on direct lead webhooks (deduplication, 90-day audit trail).
- Engineered and audited Solidity contracts using Slither, Mythril; reduced exploit risk surface by 40%.
- Created blockchain security educational content on TikTok (@tech_ale).

Project Manager

SIZLAND Limited

Nov 2025 – Mar 2026

- Orchestrated Agile/Scrum workflows in Web3 environment via JIRA and Trello; optimized task allocation and sprint delivery.
- Delivered 39k-line content curation platform and notary-mediated escrow system with smart contracts, front-end ABIs, handover documentation.
- Anticipated and mitigated project risks, conflicts, and cross-team dependencies; directed stand-ups, sprint reviews, retrospectives; liaison between developers, executives, and external partners.

Indie Game Developer (Charity Project)

Jampack Incubator

Feb 2026

- Developed and launched Mathlantis, educational web application combining math challenges with puzzle-building mechanics for Games for Love.
- Awarded "Most Child Friendly Game" title badge for accessible and engaging design.

Director and Manager

Sambu Academy

Aug 2022 – Present

- Directed educator teams delivering high-impact operations and upholding elite service standards.
- Implemented streamlined SOPs that boosted overall productivity by 30%.

Media & Production Experience

Technical Director & Firm Manager

KASS Media

Feb 2019 – Apr 2023

- Led technical operations, logistics, and firm management over multi-year tenure at a major Kenyan media station.
- Studio production, live broadcast direction, post-production editing (DaVinci Resolve, OBS Studio), camera operations, sound design, graphics, and multi-camera switching.
- Managed technical budgets, equipment procurement, vendor relationships, and cross-departmental workflows for daily news, entertainment, and special event productions.
- Trained and mentored junior technical staff; established equipment maintenance SOPs reducing downtime by 40%.

Manager: Logistics, Building and Construction

KASS Media

Feb 2019 – Aug 2022

- Oversaw facility management, construction projects, and logistics for media studio operations.

- Coordinated vendor contracts, procurement, and compliance with broadcast regulations.

Passenger Handling Agent

Swiss Port Kenya Ltd

Aug 2011 – Dec 2011

Public Relations Attaché

KEMSA

2011

Certifications & Training

Professional & Technical

- SkillQuest — Generative AI Literacy — *2026*
  SkillUP by Simplilearn ·92% ·23/25 ·Cert. No. 44822733
- CompTIA Cloud+ (CV0-003) Specialization — *In Progress*
  Coursera
- Full Stack Web3 Development Crash Course — *2024*
  Cyfrin Updraft
- Solidity Smart Contract Development — *2024*
  Cyfrin Updraft
- Smart Contract Security — *2024*
  Cyfrin Updraft
- Cybersecurity Awareness and Innovation — *2024*
  EIT Digital / Coursera
- Leveraging Virtual Assistants for Personal Productivity — *2024*
  Coursera Instructor Network
- Maximizing Organizational Trust — *2024*
  DCSA
- Develop a Company Website with Wix — *2022*
  Coursera Project Network
- Digital Forensics Masterclass: Forensic Science DFMC+ — *2024*
  Udemy
- Ethereum Blockchain Programming — *2022*
  CryptoZombies

Security & Defense Training

- Insider Threat Awareness — *2024*
  DCSA / CDSE
- Establishing an Insider Threat Program for your Organization — *2024*
  DCSA / CDSE
- Cybersecurity Awareness — *2022*
  DCSA / CDSE

Personal Development

- Non-Technical Life Skills Course — *2022*
  Completion Certificate
- Guitar Knowledge Level 1 — *2024*
  Yousician

Education

B.A. International Relations & Diplomacy with I.T.	Maseno University	2008 – Present
Certificate in HTML Web Language	Star College	2008
Kenya Certificate of Secondary Education	Milimani High School	2006 – 2007

References and portfolio available at llakterian.github.io ·CV compiled November 10, 2026